EWB COURSES

AI-POWERED CYBERSECURITY

ASSESSMENT 01

Security Foundations — Full Report with Solutions

Student Name	Majithiya Jal Anandbhai
Batch / Group	EWB – Cyber Security Internship
Assessment Date	1 Nov

Report Overview

This report answers Tasks A–D of EWB Assessment 01: Security Foundations. It uses only the fictional account scenario, suspicious-message evidence, synthetic sign-in log and fictional AI output supplied in the assessment. Conclusions are stated with appropriate uncertainty; the report does not claim to identify a real attacker or prove that a real website is malicious.

The report is organised around the assessment questions: Task A examines account risks and controls; Task B analyses a suspicious scholarship message; Task C triages a sign-in alert; and Task D corrects unsafe AI-generated security advice. Practical response steps are written for the account owner or authorised IT team.

Task A — Secure a Student Account (25 marks)

A1–A2. Risks, assets, CIA impact and controls

Mira's behaviour creates several different ways for her account and work to be exposed, changed or made unavailable. The table links each risk to an affected asset, the relevant confidentiality, integrity or availability (CIA) impact, a practical control and a limitation.

Risk	Asset at risk	CIA impact	Practical control	Limitation
1. Reused short password	Email and learning-portal accounts; messages, coursework and account data.	Confidentiality: a password exposed on one service may let someone access the other. Integrity: an intruder may change account details or coursework.	Use a unique, long password for each account, stored in a reputable password manager; change reused passwords.	A password manager itself must be protected, and a unique password cannot prevent phishing or malware theft.
2. Approving unexpected sign-in prompts	Mira's identity and access to email/learning portal.	Confidentiality: an unauthorised person may enter the account. Integrity: they may alter profile or submitted work. Availability: they may lock Mira out.	Deny unexpected prompts; approve only a sign-in Mira initiated and recognises. Report repeated prompts to IT.	A user can still be tricked or approve a prompt by mistake; MFA is not a guarantee against compromise.

3. Postponing device updates	Laptop, operating system, browser and stored project files.	Confidentiality/integrity/availability: unpatched weaknesses may be exploited to read, alter, encrypt or disrupt data.	Enable automatic updates and install security updates promptly, restarting when required.	Updates may occasionally cause compatibility issues and do not protect against every threat; backups remain necessary.
4. Only one project copy on one laptop	Project files and coursework; access to completed work.	Availability: laptop failure, theft, loss or ransomware could remove the only copy. Integrity may also be affected if files are corrupted.	Keep a separate, versioned backup in an approved cloud service or external drive; test that files can be restored.	A backup connected all the time may also be affected by ransomware; cloud access depends on account security and connectivity.
5. Friend uses laptop while Mira is signed in	Email, learning portal, private files and active sessions.	Confidentiality: friend may see private information. Integrity: accidental or intentional changes may be made. Availability: files or settings could be deleted.	Use a separate standard user account for the friend; lock the screen when away and sign out of sensitive services.	Separate accounts reduce accidental access but do not stop all physical attacks; device encryption and strong login protection are also useful.

Prioritised first three actions

1. Stop approving unexpected MFA prompts immediately. This is first because an attacker may already be attempting to sign in; denying unknown prompts interrupts the approval path. Mira should report repeated prompts to the college IT team.
2. Replace the reused password with a unique, strong password on the email account and learning portal. Email is especially important because it may be used to reset other accounts. If compromise is suspected, use a trusted device and the official account-recovery process; sign out other sessions where the service provides that option.
3. Create and verify a separate backup of the project files. This protects the only copy against laptop loss, hardware failure or malicious encryption. After these urgent steps, update the laptop and establish a separate user account for the friend.

A3. Authentication versus authorisation

Authentication answers “Who are you?” When Mira signs in to the learning portal, she proves her identity using her account credentials and, where enabled, a second factor such as an authenticator approval. Authorisation answers “What are you allowed to do?” After authentication, the portal checks Mira’s assigned permissions. For example, a student account may be allowed to view course materials, upload assignments and view its own grades, but not change another student’s grades or administer the portal. Successful authentication does not automatically grant every permission.

Task B — Analyse a Suspicious Message (25 marks)

B1. Warning signs in the supplied evidence

The message should be treated as suspicious and verified independently. These indicators justify caution, but the supplied text alone does not prove who sent it or whether the linked site is malicious.

Quoted evidence	Why it needs scrutiny
"From: Scholarship Desk <awards@campus-awards.example>" and "Reply-To: help@personal-awards.example"	The reply address uses a different domain from the displayed sender and from the college's stated normal domain, campus.example. A mismatch can route replies to an unrelated party and needs independent checking.
"FINAL WARNING" and "expires in 20 minutes"	Urgency and a short deadline pressure the recipient to act before checking the request. Legitimate deadlines should be confirmed through the college's normal channels.
"enter your college password and OTP"	A request to provide both a password and one-time passcode is highly dangerous. These are authentication secrets and should never be sent in response to an unsolicited message or entered on an unverified page.
"Do not contact the college office"	The sender discourages independent verification and attempts to isolate the recipient from a trusted source. This is a strong social-engineering warning sign.
"Reply with a photo of your identity card"	The request seeks sensitive identity information that is not appropriate to send by ordinary email without verified necessity and a secure official process.

B2. Safe verification process

4. Do not click the link, reply, open attachments or provide credentials, OTPs or identity documents. Preserve the message for reporting.
5. Open the college portal using a saved bookmark or an address obtained independently from official college materials. Alternatively, call or visit the college office using a phone number obtained from an official directory—not a number or link in the message.
6. Ask the scholarship or finance office whether the award, deadline and requested documents are genuine. Share the message headers or a screenshot through the college's approved reporting channel if requested, while avoiding unnecessary exposure of personal information.

HTTPS only indicates that the browser has an encrypted connection to the domain shown; it does not establish that the domain belongs to the college or that its operator is trustworthy. A familiar

display name can be chosen by a sender and is not reliable proof of identity. The domain, sender authentication details and request must be checked through an independent official channel.

B3. If a student already entered a password and OTP

7. Contain the incident immediately. From a trusted device, use the college's official portal or account-recovery page to change the affected password to a new, unique one. Do not reuse the exposed password.
8. Contact the college IT/security team using an independently verified contact method and state that the password and OTP may have been disclosed. Ask IT to revoke active sessions or tokens, review sign-in activity and apply any account-protection steps available.
9. If the same password was used elsewhere, change it on those services too, beginning with the email account. Use each service's official site and a different password.
10. Report the message to the college's phishing/security reporting channel. Keep the original email and its headers if possible; do not forward it widely or interact with the sender.
11. Check recent sign-ins, recovery details, forwarding rules, MFA methods and account changes with IT. Watch for unauthorised messages, password-reset notices or changes to personal information. Do not send the password or OTP to the person helping.

B4. What cannot be established from this message alone

The actual identity and intent of the sender cannot be established from the displayed From and Reply-To fields or message wording alone. Additional evidence could include full email headers (including authentication results such as SPF, DKIM and DMARC), mail-server trace information, and confirmation from the college's scholarship office. Even these should be interpreted by authorised staff; the assessment asks for analysis of the supplied text, not a definitive attribution.

Task C — Triage a Sign-in Alert (25 marks)

C1. Four-point timeline: observations and interpretation

Time	Observed events	Interpretation
18 Oct, 09:00–09:01	Observed: student07 password sign-in succeeded from 192.0.2.10; MFA was approved one minute later.	This matches the lab note identifying 192.0.2.10 as the usual classroom egress. It is a baseline event, not evidence of compromise.
18 Oct, 10:14–10:15	Observed: two password attempts from 198.51.100.23 failed.	The repeated failures may indicate a mistyped password or an attempted unauthorised sign-in. The IP difference alone does not identify an attacker.
18 Oct, 10:16–10:18	Observed: password succeeded from 198.51.100.23; an MFA prompt was first denied and then approved. User says they did not sign in after 09:05 and approved a prompt at about 10:18 to stop repeated requests.	The successful password event followed by the user's unexpected MFA approval is consistent with a possible credential compromise and MFA-prompt manipulation. The approval may have enabled the session.
18 Oct, 10:20	Observed: a session was created from 198.51.100.23.	This shows that an authenticated session was established after the password success and MFA approval. It does not by itself establish who controlled the source IP or what actions occurred in the session.

C2. Likely explanation, alternative and distinguishing checks

Likely explanation: someone other than student07 may have obtained the password and attempted to sign in. After two failed attempts, the password succeeded; the user then approved an unexpected MFA prompt because they wanted the repeated requests to stop. That approval may have allowed the session to be created at 10:20. The sequence is consistent with credential compromise combined with MFA-prompt manipulation, but it is not conclusive proof.

Alternative explanation: the activity may have resulted from a legitimate but unrecognised sign-in process—for example, a user action or service retry from a different network—combined with confusion about the MFA prompt. The student's statement makes this less likely, but the available log is too limited to rule it out.

- Check the identity provider's detailed audit records: device/browser details, session identifiers, MFA method and challenge metadata, geolocation estimates, risk flags and any token issuance. Compare these with the student's known devices and activity. Geolocation and IP information are clues, not proof of a person's identity.
- Interview student07 through an approved channel and review relevant account activity after session creation, including accessed resources, password or recovery changes, mailbox/portal settings and subsequent sign-ins. Preserve relevant records before taking actions that may overwrite them.

C3. Three prioritised actions for the authorised IT team

12. Protect the account and contain access. Contact the student through a verified channel, reset the password using the approved process, revoke active sessions/refresh tokens where supported, and require fresh MFA enrolment or verification if compromise is suspected. Review recovery methods and account changes.
13. Preserve evidence before routine log rotation or deletion. Export the relevant authentication, MFA and session logs with timestamps and time zone, retain message/alert context, record who collected the evidence and when, and follow the institution's evidence-handling procedure. Do not delete suspicious logs.
14. Investigate scope and monitor. Review activity before and after 10:16, identify resources accessed by the new session, check for persistence or changed settings, and monitor for further failed attempts or unexpected MFA requests. Escalate under the college incident-response process and document decisions.

C4. Incident summary (60–100 words)

On 18 October 2026, student07 had a normal password and MFA sign-in from the usual classroom egress at 09:00–09:01. At 10:14–10:15, two password attempts from a different documentation IP failed; a password then succeeded at 10:16. MFA was denied and subsequently approved at 10:18, and a session was created at 10:20. The student denies initiating the sign-in and reports approving the prompt to stop repeated requests. Possible credential compromise is the priority, but attribution is uncertain. IT should preserve logs, contain the session and investigate account activity.

Task D — Review an AI Security Answer (25 marks)

D1. Five unsafe or unsupported claims/actions and corrections

AI statement/action	Correction and reasoning
"The email is safe because it uses HTTPS."	Incorrect. HTTPS encrypts the connection but does not prove that a site is operated by the college or that the request is legitimate. Verify the domain and scholarship through an independently obtained official portal or contact.
"The sign-in logs prove that the person using 198.51.100.23 stole the password."	Unsupported attribution. The logs show events associated with a source IP, not the identity of a person or how a password was obtained. Treat the sequence as suspicious and corroborate it with device, session and audit evidence.
"MFA prevents every account compromise."	False absolute claim. MFA adds a security layer, but users can approve unexpected prompts, and some MFA methods can be abused. Users should deny unrecognised prompts and report repeated requests; IT should review and strengthen authentication controls.
"Delete the suspicious logs."	Unsafe. Logs are evidence needed to understand scope, timeline and impact. Preserve relevant records according to the organisation's incident-response and retention procedures; do not delete or alter them.
"Send the student's password to support so they can test it."	Never request or share passwords or OTPs. Support staff should use approved identity-verification and password-reset procedures. The student should change exposed credentials through the official portal and IT should revoke sessions as appropriate.

D2. Improved prompt for an AI tool

Analyse only the fictional evidence included below: the scholarship-message text and the synthetic sign-in log. Do not browse, visit links, identify or accuse a real person, or assume that an IP address identifies an individual. Separate (1) directly observed facts, (2) reasonable interpretations, and (3) unknowns. For each concern, explain which supplied evidence supports it and what additional evidence would be needed. Recommend safe, proportionate actions for the student and authorised college IT staff. Do not ask for,

reproduce or suggest sharing passwords, OTPs, identity documents or other secrets. State uncertainty clearly, avoid absolute claims, and do not invent facts or references. If the supplied evidence cannot answer a question, say so.

D3. Corrected security advice (100–150 words)

Treat the scholarship message as unverified. Do not open its link, reply, or provide a password, OTP or identity-card photo. Confirm the award using the college portal reached through a saved bookmark or contact the scholarship office using details from an official college source. HTTPS and a familiar sender name do not prove legitimacy. The sign-in log shows a password success, an MFA approval and a later session from an unfamiliar documentation IP; it does not identify a person or prove how the password was obtained. If the student did not initiate the sign-in, they should contact IT through a verified channel, change the password on the official portal and ask IT to revoke sessions and review account activity. Preserve the original message and relevant logs.

D4. AI-use declaration and evidence/reference notes

AI-use declaration: AI assistance was used to help organise and draft this report and to explain the supplied fictional scenarios. The assessment evidence and conclusions were checked against the wording of the EWB Assessment 01 brief. No live websites were visited, no public systems were scanned, and no real credentials or personal data were used. The student should review and edit this draft in their own words before submission.

Evidence note 1 — EWB Assessment 01, pages 1–3: Task A account scenario; Task B fictional scholarship-message evidence; and Task C synthetic sign-in log and student statement. These are the primary evidence for the report's scenario-specific findings.

Evidence note 2 — EWB Assessment 01, page 4: the brief lists CISA Secure Our World for basic account and phishing guidance and NIST AI 600-1 for issues such as AI confabulation and verification. These are the references specified by the assessment.

References

- EWB Courses. Assessment 01: Security Foundations, AI-Powered Cybersecurity. Issued 18 October 2026, pages 1–4. Supplied assessment brief.
- Cybersecurity and Infrastructure Security Agency (CISA). Secure Our World. https://www.cisa.gov/secure-our-world
- National Institute of Standards and Technology (NIST). Artificial Intelligence Risk Management Framework: Generative Artificial Intelligence Profile, NIST AI 600-1. https://nvlpubs.nist.gov/nistpubs/ai/NIST.AI.600-1.pdf